CyberDefenders

RESOLUCIÓN DE LABORATORIO

Caso: HawkEye (CyberDefenders)

Investigación de Respuesta a Incidentes centrada en el análisis de paquetes de red para mapear la infraestructura C2, identificar vectores de exfiltración encubiertos y aislar las credenciales robadas por una variante de HawkEye Keylogger.

Sebastian David
Torres Reyes

Escenario:

Un contador de su organización recibió un correo electrónico sobre una factura con un enlace de descarga. Se observó tráfico de red sospechoso poco después de abrir el correo. Como analista del SOC, investigue el rastreo de red y analice los intentos de exfiltración.

Herramientas utilizadas:

- Wireshark
- NetworkMiner
- MaxMind Geo IP
- QuickHash
- CyberChef

P1: ¿Cuántos paquetes tiene la captura?

R: 4003

Se usó Wireshark para el análisis de tráfico de red y se detectaron 4003 paquetes.

No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
3985	2019-04-10 16:40:48.462330	10.4.10.132	56879	10.4.10.4	53	DNS	92	Standard query 0x7eb6 A PizzaJuk
3986	2019-04-10 16:40:48.462558	10.4.10.4	53	10.4.10.132	56879	DNS	108	Standard query response 0x7eb6 A
3987	2019-04-10 16:40:48.464181	10.4.10.132	49228	10.4.10.4	445	TCP	66	49228 → 445 [SYN] Seq=0 Win=8192
3988	2019-04-10 16:40:48.464367	10.4.10.4	445	10.4.10.132	49228	TCP	66	445 → 49228 [SYN, ACK] Seq=0 Ack
3989	2019-04-10 16:40:48.464474	10.4.10.132	49228	10.4.10.4	445	TCP	54	49228 → 445 [ACK] Seq=1 Ack=1 Wi
3990	2019-04-10 16:40:48.464530	10.4.10.132	49228	10.4.10.4	445	SMB	213	Negotiate Protocol Request
3991	2019-04-10 16:40:48.464813	10.4.10.4	445	10.4.10.132	49228	SMB2	306	Negotiate Protocol Response
3992	2019-04-10 16:40:48.464890	10.4.10.132	49228	10.4.10.4	445	SMB2	162	Negotiate Protocol Request
3993	2019-04-10 16:40:48.465155	10.4.10.4	445	10.4.10.132	49228	SMB2	306	Negotiate Protocol Response
3994	2019-04-10 16:40:48.466002	10.4.10.132	49228	10.4.10.4	445	TCP	1514	49228 → 445 [ACK] Seq=268 Ack=50
3995	2019-04-10 16:40:48.466009	10.4.10.132	49228	10.4.10.4	445	TCP	1514	49228 → 445 [ACK] Seq=1728 Ack=5
3996	2019-04-10 16:40:48.466102	10.4.10.4	445	10.4.10.132	49228	TCP	54	445 → 49228 [ACK] Seq=505 Ack=31
3997	2019-04-10 16:40:48.466164	10.4.10.132	49228	10.4.10.4	445	SMB2	420	Session Setup Request
3998	2019-04-10 16:40:48.481359	10.4.10.4	445	10.4.10.132	49228	SMB2	314	Session Setup Response
3999	2019-04-10 16:40:48.481853	10.4.10.132	49228	10.4.10.4	445	SMB2	208	Tree Connect Request, Tree: '\\P
4000	2019-04-10 16:40:48.481985	10.4.10.4	445	10.4.10.132	49228	SMB2	138	Tree Connect Response, Tree: '\\
4001	2019-04-10 16:40:48.482243	10.4.10.132	49228	10.4.10.4	445	SMB2	182	Ioctl Request FSCTL_DFS_GET_REFE
4002	2019-04-10 16:40:48.482391	10.4.10.4	445	10.4.10.132	49228	SMB2	278	Ioctl Response FSCTL_DFS_GET_REF
4003	2019-04-10 16:40:48.690963	10.4.10.132	49228	10.4.10.4	445	TCP	54	49228 → 445 [ACK] Seq=3836 Ack=1

P2: ¿A qué hora se capturó el primer paquete (UTC)?

R: 2019-04-10 20:37

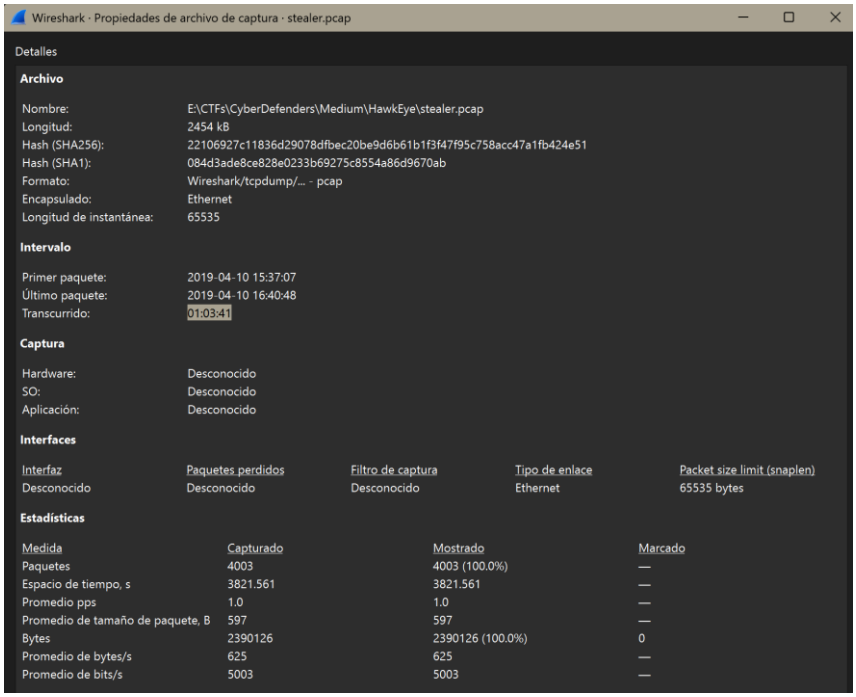
El tiempo en el que se capturó el primer paquete fue 2019-04-10 20:37.

No.	Time	Source
1	2019-04-10 20:37:07.12973…	10.4.10.132
2	2019-04-10 20:37:07.12981…	10.4.10.4
3	2019-04-10 20:37:07.12986…	10.4.10.132

P3: ¿Cuál es la duración de la captura?

R: 01:03:41

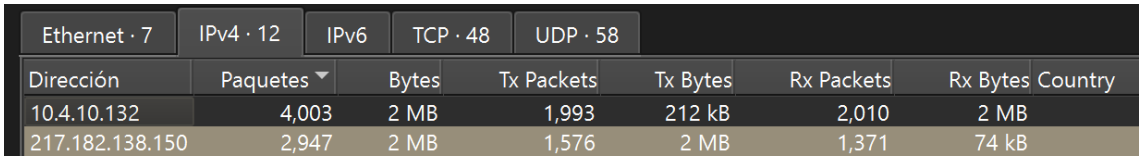
En las propiedades de archivo de captura se observó que la duración de la captura fue 01:03:41.

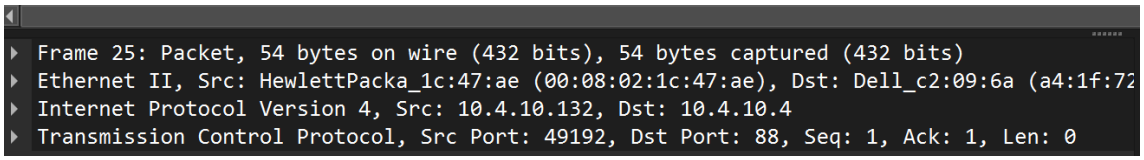


P4: ¿Cuál es el ordenador más activo a nivel de enlace?

R: 00:08:02:1c:47:ae

En la ventana de “Endpoints” se determinó que la dirección IP del ordenador más activo fue 10.4.10.132 y la dirección MAC 00:08:02:1c:47:ae.





P5: ¿Fabricante de la NIC del sistema más activo a nivel de enlace?

R: Hewlett-Packard

Para encontrar la información de la NIC se usó el OUI de la dirección MAC y el sitio web macaddress.io. El nombre del fabricante es Hewlett Packard.

Vendor details

OUI	00:08:02
Is private	False
Company name	Hewlett Packard
Company address	20555 State Highway 249 Houston TX 77070 US
Country code	US

P6: ¿Dónde está la sede de la empresa que fabricó la NIC del ordenador más activo a nivel de enlace?

R: Palo Alto

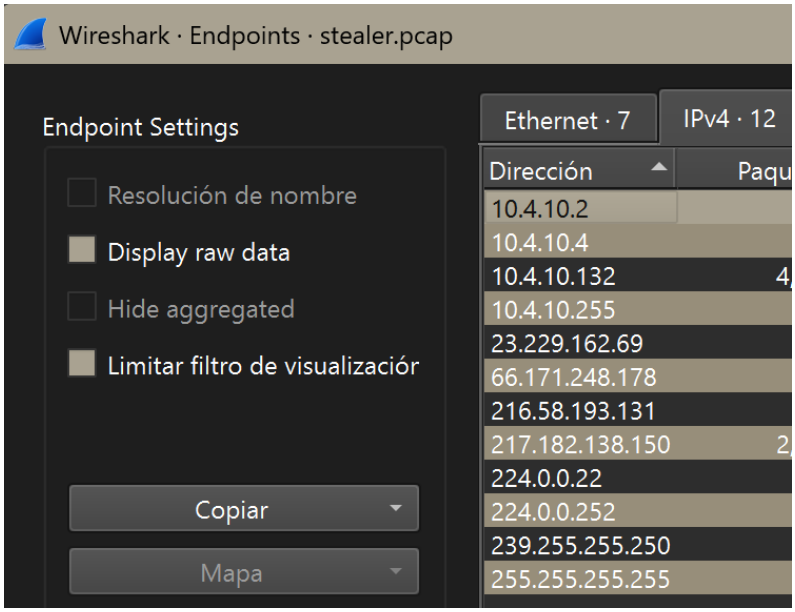
La sede de la compañía del fabricante es Palo Alto.

Hewlett-Packard Company (NYSE: HPQ), más conocida como **HP**, es una empresa de tecnología estadounidense, con sede en Palo Alto, California, dedicada a la fabricación y comercialización de *hardware* y *software* además de brindar servicios de asistencia relacionados con la informática. La compañía fue fundada en 1939 por William Hewlett y David Packard, y se dedicaba a la fabricación de instrumentos de medida electrónica y de laboratorio.

P7: La organización trabaja con direccionamiento privado y máscara de red /24. ¿Cuántas computadoras de la organización participan en la captura?

R: 3

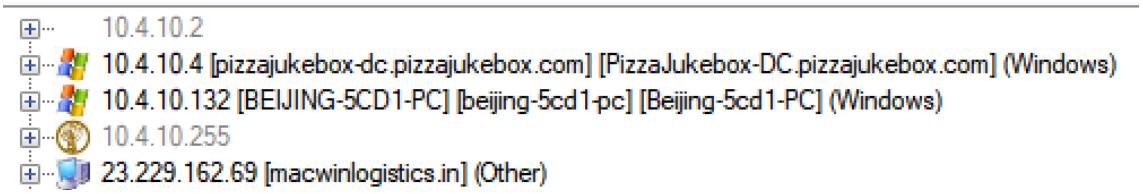
En la ventana de “Endpoints” se observaron 3 direcciones IP pertenecientes a la misma red privada, la dirección 10.4.10.255 es una dirección de difusión.



P8: ¿Cómo se llama la computadora más activa a nivel de red?

R: BEIJING-5CD1-PC

Se usó la herramienta NetworkMiner que nos proporciona una mejor perspectiva de la información de cada host involucrado en la captura. El nombre de la computadora más activa con la dirección IP 10.4.10.132 es BEIJING-5CD1-PC.



P9: ¿Cuál es la IP del servidor DNS de la organización?

R: 10.4.10.4

Se filtraron los paquetes DNS en Wireshark y se visualizó que la dirección IP 10.4.10.4 recibe todos los paquetes DNS query.

dns

No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
116	2019-04-10 20:37:33.37747…	10.4.10.132	51699	10.4.10.4	53	DNS	134	Standard query 0x9a2c SRV _ldap._tcp.
117	2019-04-10 20:37:33.37774…	10.4.10.4	53	10.4.10.132	51699	DNS	213	Standard query response 0x9a2c No suc
118	2019-04-10 20:37:33.37824…	10.4.10.132	53083	10.4.10.4	53	DNS	103	Standard query 0x3ee5 SRV _ldap._tcp.
119	2019-04-10 20:37:33.37839…	10.4.10.4	53	10.4.10.132	53083	DNS	182	Standard query response 0x3ee5 No suc
174	2019-04-10 20:37:33.91165…	10.4.10.132	53233	10.4.10.4	53	DNS	76	Standard query 0x8701 A dns.msftncsi.
177	2019-04-10 20:37:33.93798…	10.4.10.4	53	10.4.10.132	53233	DNS	92	Standard query response 0x8701 A dns.
204	2019-04-10 20:37:53.79101…	10.4.10.132	54662	10.4.10.4	53	DNS	81	Standard query 0xa002 A proforma-invo
206	2019-04-10 20:37:54.57701…	10.4.10.4	53	10.4.10.132	54662	DNS	97	Standard query response 0xa002 A prof
3159	2019-04-10 20:38:15.67228…	10.4.10.132	61583	10.4.10.4	53	DNS	85	Standard query 0x3f59 A bot.whatismyi
3160	2019-04-10 20:38:15.70614…	10.4.10.4	53	10.4.10.132	61583	DNS	101	Standard query response 0x3f59 A bot.
3170	2019-04-10 20:38:15.83200…	10.4.10.132	59471	10.4.10.4	53	DNS	78	Standard query 0x3daa A macwinlogisti
3171	2019-04-10 20:38:15.91295…	10.4.10.4	53	10.4.10.132	59471	DNS	94	Standard query response 0x3daa A macw
3268	2019-04-10 20:47:58.64186…	10.4.10.132	51945	10.4.10.4	53	DNS	81	Standard query 0x65d6 A update.google
3269	2019-04-10 20:47:58.67507…	10.4.10.4	53	10.4.10.132	51945	DNS	97	Standard query response 0x65d6 A upda
3290	2019-04-10 20:48:20.05466…	10.4.10.132	64679	10.4.10.4	53	DNS	85	Standard query 0x3119 A bot.whatismyi
3291	2019-04-10 20:48:20.07759…	10.4.10.4	53	10.4.10.132	64679	DNS	101	Standard query response 0x3119 A bot.
3301	2019-04-10 20:48:20.20321…	10.4.10.132	61356	10.4.10.4	53	DNS	78	Standard query 0x50d8 A macwinlogisti
3302	2019-04-10 20:48:20.33449…	10.4.10.4	53	10.4.10.132	61356	DNS	94	Standard query response 0x50d8 A macw
3377	2019-04-10 20:58:24.36558…	10.4.10.132	59430	10.4.10.4	53	DNS	85	Standard query 0x54a6 A bot.whatismyi

P10: ¿Sobre qué dominio pregunta la víctima en el paquete 204?

R: proforma-invoices.com

El paquete 204 usó el protocolo DNS, en el panel de detalles se halló que el dominio que preguntó la víctima fue proforma-invoices.com.

```
▸ Frame 204: Packet, 81 bytes on wire (648 bits), 81 bytes captured (648 bits)
▸ Ethernet II, Src: HewlettPacka_1c:47:ae (00:08:02:1c:47:ae), Dst: Dell_c2:09:6a (a4:1f:7
▸ Internet Protocol Version 4, Src: 10.4.10.132, Dst: 10.4.10.4
▸ User Datagram Protocol, Src Port: 54662, Dst Port: 53
▾ Domain Name System (query)
    Transaction ID: 0xa002
  ▸ Flags: 0x0100 Standard query
    Questions: 1
    Answer RRs: 0
    Authority RRs: 0
    Additional RRs: 0
  ▾ Queries
    ▸ proforma-invoices.com: type A, class IN
    [Response In: 206]
```

P11: ¿Cuál es la IP del dominio de la pregunta anterior?

R: 217.182.138.150

Luego del paquete DNS query preguntando por el dominio proforma-invoices.com el servidor DNS emite una respuesta con la dirección IP resuelta 217.182.138.150.

```
    Authority RRs: 0
    Additional RRs: 0
  ▾ Queries
    ▾ proforma-invoices.com: type A, class IN
        Name: proforma-invoices.com
        [Name Length: 21]
        [Label Count: 2]
        Type: A (1) (Host Address)
        Class: IN (0x0001)
  ▾ Answers
    ▾ proforma-invoices.com: type A, class IN, addr 217.182.138.150
        Name: proforma-invoices.com
        Type: A (1) (Host Address)
        Class: IN (0x0001)
        Time to live: 14398 (3 hours, 59 minutes, 58 seconds)
        Data length: 4
        Address: 217.182.138.150
    [Request In: 204]
    [Time: 786.002000 milliseconds]
```

P12: Indique el país al que pertenece la IP del apartado anterior.

R: France

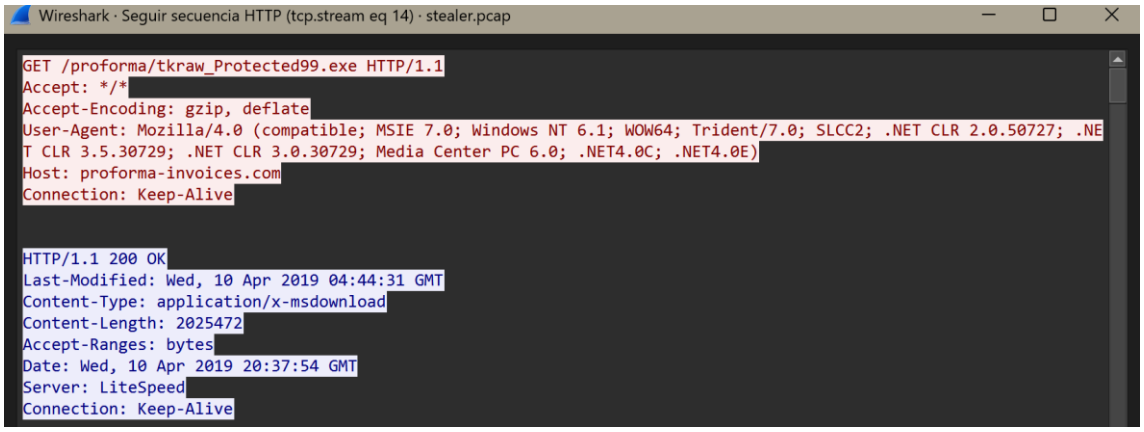
Mediante la herramienta de inteligencia de red MaxMind Geo IP, se geolocalizó la dirección IP 217.182.138.150. El análisis determinó que la infraestructura de alojamiento utilizada por el atacante se encuentra físicamente en Francia.

IP Address	Location	Network	Postal Code	Approximate Latitude / Longitude*, and Accuracy Radius	ISP / Organization	Domain	Connection Type
217.182.138.150	France (FR), Europe	217.182.138.0/24	-	48.8582, 2.3387 (500 km)	OVHcloud	ip-217-182-138.eu	Corporate

P13: ¿Qué sistema operativo utiliza el ordenador de la víctima?

R: Windows NT 6.1

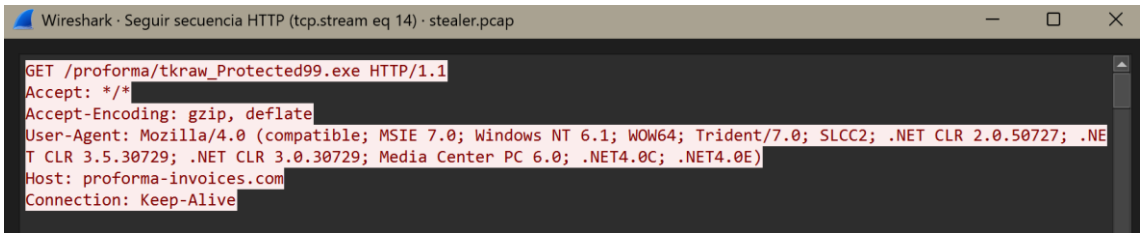
El Header User-Agent de la dirección IP de la víctima 10.4.10.132 muestra el SO del ordenador Windows NT 6.1.



P14: ¿Cuál es el nombre del archivo malicioso descargado por el contador?

R: tkraw_Protected99.exe

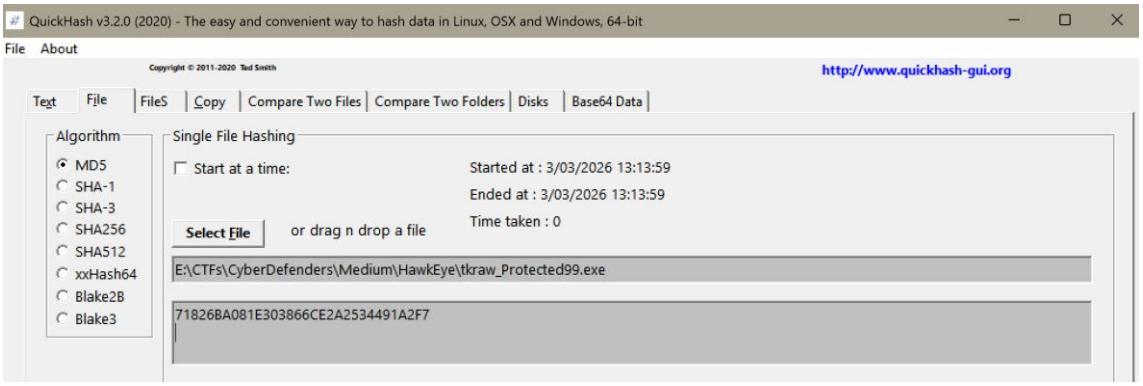
La víctima envía un paquete HTTP con el método GET y descarga el archivo tkraw_Protected99.exe.



P15: ¿Cuál es el hash md5 del archivo descargado?

R: 71826BA081E303866CE2A2534491A2F7

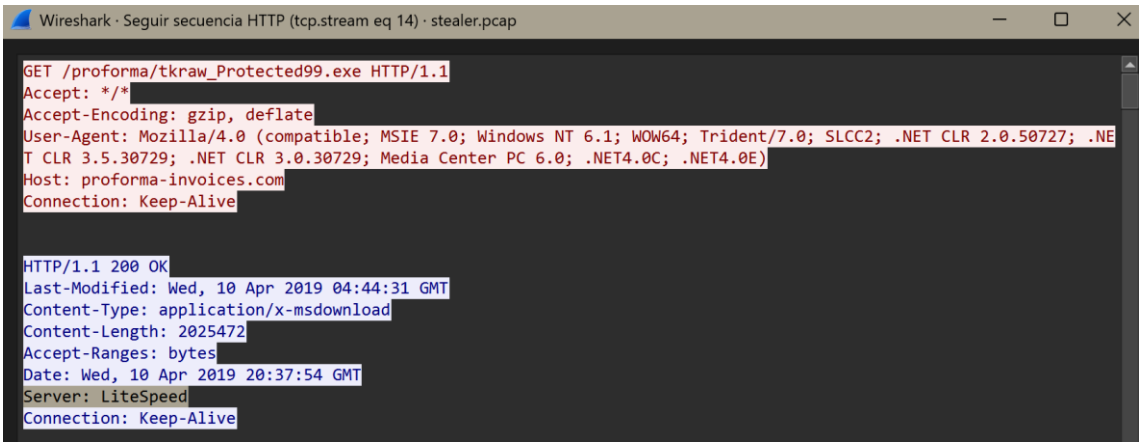
Tras aislar el tráfico de red, se extrajo el payload (el archivo tkraw_Protected99.exe) exportando los objetos HTTP desde Wireshark. Posteriormente, se utilizó la utilidad QuickHash para generar el hash MD5 del artefacto recuperado, resultando en: 71826BA081E303866CE2A2534491A2F7.



P16: ¿Qué software ejecuta el servidor web que aloja el malware?

R: LiteSpeed

El software que ejecuta el servidor web es LiteSpeed.



P17: ¿Cuál es la IP pública de la computadora de la víctima?

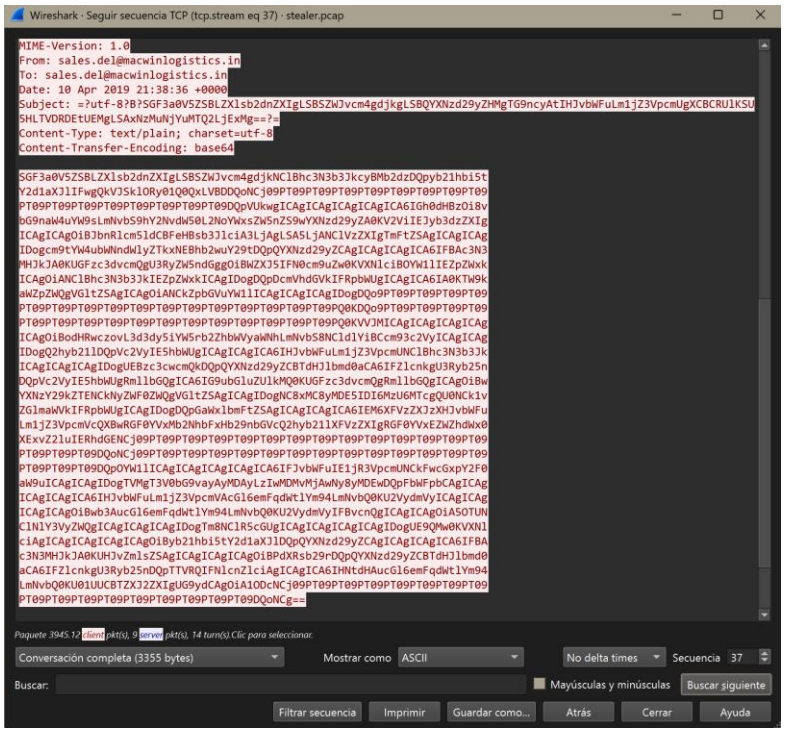
R: 173.66.146.112

Durante la ejecución del malware, se observó que el host comprometido emitió una consulta DNS para el dominio bot.whatismyipaddress.com (IP 66.171.248.178). Al seguir la secuencia HTTP (TCP Stream), se comprobó que el atacante utilizó este servicio legítimo para que el ejecutable malicioso descubriera y registrara la dirección IPv4 pública de la red de la víctima, la cual es 173.66.146.112.

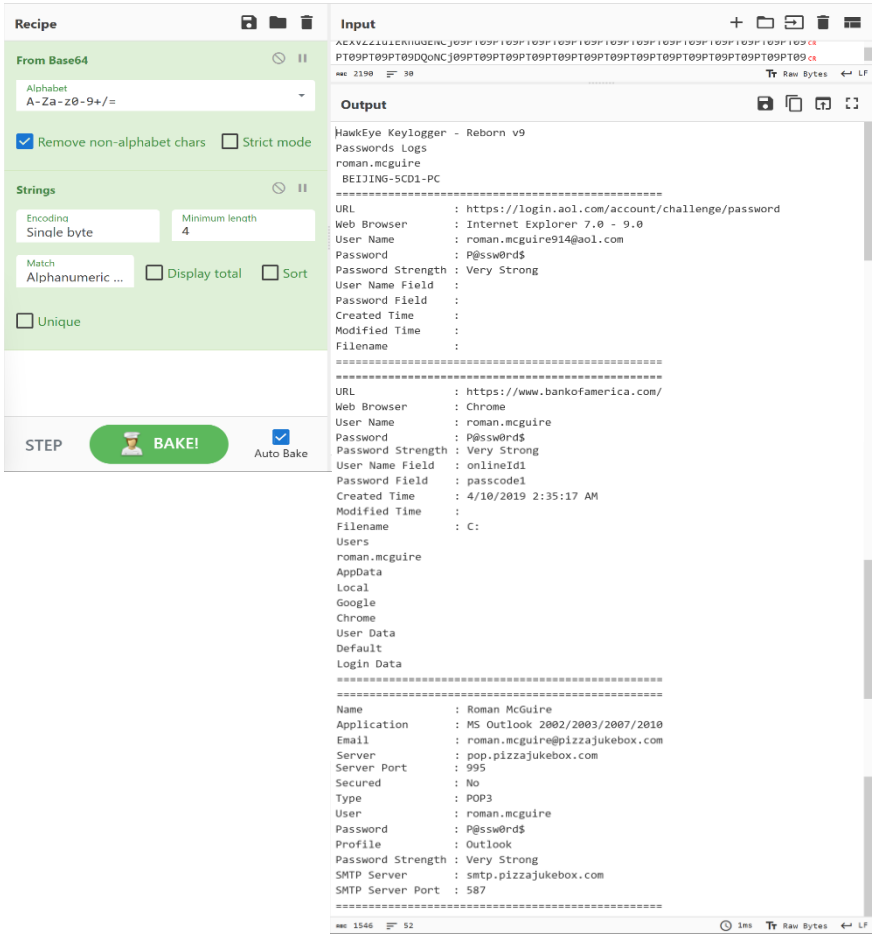
P18: ¿En qué país se encuentra el servidor de correo electrónico al que se envía la información robada?

R: United States

Tras la infección inicial, el análisis de la comunicación (filtrando por TCP y SMTP) reveló que el malware establece un canal de exfiltración de datos hacia la IP 23.229.162.69. El artefacto actúa como un keylogger, capturando pulsaciones y enviando la información robada periódicamente mediante correos electrónicos automatizados. Para evadir la detección en texto plano, el contenido de estos correos es ofuscado utilizando codificación Base64.



Una vez decodificado con la herramienta CyberChef se puede determinar que el keylogger envía las credenciales de las cuentas de la víctima.



Finalmente, el servidor SMTP del correo electrónico sales.del@macwinlogistics.in de dirección IP 23.229.162.69 que tiene acceso a los correos enviados, obtendrá las credenciales de la víctima.

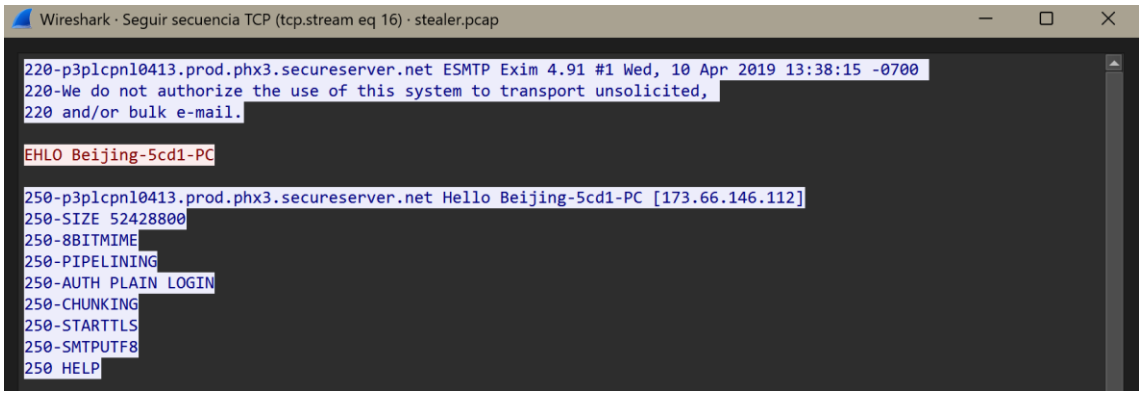
Para obtener información sobre el servidor SMTP se usó MaxMind Geo IP. El servidor se encuentra en Estados Unidos.

IP Address	Location	Network	Postal Code	Approximate Latitude / Longitude*, and Accuracy Radius	ISP / Organization	Domain	Connection Type
23.229.162.69	United States (US), North America	23.229.128.0/17	-	37.751, -97.822 (1000 km)	GoDaddy.com	secureserver.net	Corporate

P19: Analizando la primera extracción de información. ¿Qué software ejecuta el servidor de correo electrónico al que se envían los datos robados?

R: Exim 4.91

Se puede observar el software que ejecuta el servidor de correo electrónico del atacante en el encabezado de los paquetes donde estuvo involucrado el mismo. El software es ESMTP Exim 4.91.



P20: ¿A qué cuenta de correo electrónico se envía la información robada?

R: sales.del@macwinlogistics.in

El keylogger envía la información robada a su misma cuenta. El nombre de la cuenta de correo electrónico es sales.del@macwinlogistics.in.

```
235 Authentication succeeded

MAIL FROM:<sales.del@macwinlogistics.in>

250 OK

RCPT TO:<sales.del@macwinlogistics.in>

250 Accepted
```

P21: ¿Cuál es la contraseña que utiliza el malware para enviar el correo electrónico?

R: Sales@23

Si se realiza el seguimiento de los paquetes TCP donde participó la dirección IP del servidor del atacante se puede encontrar las credenciales de la cuenta que usa el keylogger. Estas credenciales también están codificadas en base64.

```
AUTH login c2FsZXMuZGVsQG1hY3dpbmxvZ2lzdGljcy5pbg==

334 UGFzc3dvcmQ6

U2FsZXNAMjM=

235 Authentication succeeded
```

Nuevamente se usó la herramienta CyberChef y se pudo encontrar el correo y contraseña que usa el malware.

c2FsZXMuZGVsQG1hY3dpbmxvZ2lzdGljcy5pbg==	sales.del@macwinlogistics.in
UGFzc3dvcmQ6	Password:
U2FsZXNAMjM=	Sales@23

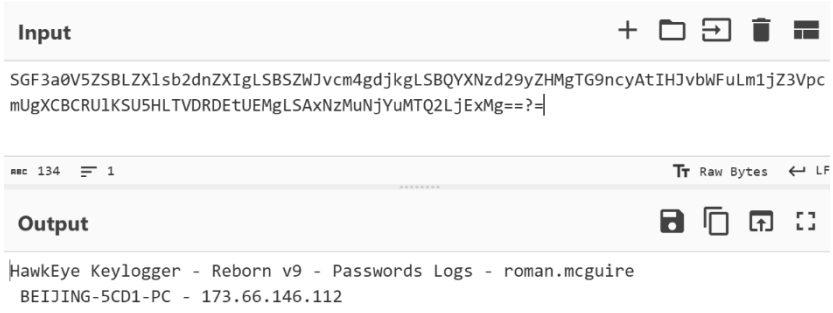
P22: ¿Qué variante de malware exfiltró los datos?

R: Reborn V9

En el etiquetado de la exfiltración de datos se puede ver que está codificado en base64 también.

```
MIME-Version: 1.0
From: sales.del@macwinlogistics.in
To: sales.del@macwinlogistics.in
Date: 10 Apr 2019 20:38:08 +0000
Subject: =?utf-8?B?SGF3a0V5ZSBLZXlsb2dnZXIgLSBSZWJvcm4gdjkgLSBQYXNzd29yZHMgTG9ncyAtIHJvbWFuLm1jZ3VpcmUgXCBCRUlKSU
5HLTVDRDEtUEMgLSAxNzMuNjYuMTQ2LjExMg==?=
Content-Type: text/plain; charset=utf-8
Content-Transfer-Encoding: base64
```

Al decodificarlo podemos saber que la variante es Reborn V9.



P23: ¿Cuáles son las credenciales de acceso de BankofAmerica? (usuario:contraseña)

R: roman.mcguire:P@ssw0rd$

Anteriormente se decodifico el contenido del correo. El usuario es roman.mcguire y la contraseña es P@ssw0rd$.

```
==================================================
URL               : https://www.bankofamerica.com/
Web Browser       : Chrome
User Name         : roman.mcguire
Password          : P@ssw0rd$
Password Strength : Very Strong
User Name Field   : onlineId1
Password Field    : passcode1
Created Time      : 4/10/2019 2:35:17 AM
Modified Time     :
Filename          : C:
Users
roman.mcguire
AppData
Local
Google
Chrome
User Data
Default
Login Data
==================================================
```

P24: ¿Cada cuántos minutos se exfiltran los datos recopilados?

R: 10

Al correlacionar las marcas de tiempo de los paquetes SMTP salientes en Wireshark, se identificó un patrón de comunicación regular (Beaconing). La primera ráfaga de exfiltración ocurrió a las 20:38:16 UTC, seguida por una segunda transmisión a las 20:48:20 UTC, así sucesivamente. Esto confirma que el malware está programado en su configuración interna para empaquetar y exfiltrar los datos robados en intervalos exactos de 10 minutos.

3175	2019-04-10 20:38:16.28994…	23.229.162.69	587	10.4.10.132	49206	SMTP	251	S: 220-p3plcpnl0413.prod.phx3.secure
3306	2019-04-10 20:48:20.64640…	23.229.162.69	587	10.4.10.132	49211	SMTP	251	S: 220-p3plcpnl0413.prod.phx3.secures